



Case Study on Penetration Testing Using the Ethical Hacking Process based on Rules of Engagement

Objective

Select any one organization/domain and design a complete penetration testing engagement following the ethical hacking process. Students should prepare a Rules of Engagement document, define the testing methodology, identify possible vulnerabilities, and develop a client questionnaire.

Domains (Choose Any One)

1. Hospital Management System
2. Banking and Financial Services
3. E-commerce Website
4. University Campus Network
5. Government Portal
6. Smart City Infrastructure
7. Cloud Service Provider
8. Manufacturing Industry
9. Hotel Management System
10. Airport Information System
11. Online Education Platform
12. Retail Store Chain
13. Telecom Network
14. Healthcare IoT Devices
15. Social Media Platform

Case Study Requirements

Part A – Organization Overview

Describe the selected organization.

Include:

- Domain
- Number of employees

- Network architecture
- Critical assets
- IT infrastructure
- Web applications
- Databases
- Cloud services
- Third-party integrations

Part B – Scope of Penetration Testing

Clearly define:

In Scope

Example

- Public website
- Internal network
- Email server
- Wireless network
- Employee portal
- VPN Gateway

Out of Scope

Example

- Production database deletion
- Physical attacks
- Social engineering
- Denial-of-Service attacks
- Employee personal devices

Part C – Rules of Engagement (RoE)

Prepare a professional Rules of Engagement document containing:

1. Objective of the assessment
2. Scope
3. Timeline

4. Testing window
5. Authorized personnel
6. Communication plan
7. Emergency contacts
8. Allowed testing activities
9. Prohibited activities
10. Confidentiality agreement
11. Reporting procedure
12. Risk acceptance
13. Legal authorization

Part D – Ethical Hacking Methodology

Explain how penetration testing will be performed.

Phase 1

Planning and Pre-engagement

- Obtain authorization
- Define objectives
- Finalize scope
- Prepare Rules of Engagement

Phase 2

Reconnaissance

Possible activities

- WHOIS
- DNS Enumeration
- Google Dorking
- OSINT
- Subdomain Enumeration

Mention the tools that could be used.

Phase 3

Scanning and Enumeration

Possible activities

- Port Scanning
- Service Enumeration
- Vulnerability Scanning
- Network Mapping

Mention suitable tools.

Phase 4

Vulnerability Analysis

Identify possible vulnerabilities such as

- SQL Injection
- Cross-Site Scripting
- Weak Password Policy
- Open Ports
- Misconfigured Servers
- Outdated Software
- Missing Security Headers

Assign a severity:

- Critical
- High
- Medium
- Low

Phase 5

Controlled Exploitation

Explain **how vulnerabilities would be validated in a safe, authorized manner** without causing disruption. Describe the expected evidence that confirms the vulnerability and the precautions taken during testing.

Phase 6

Post-Exploitation

Discuss only authorized post-exploitation activities, such as:

- Verifying the impact of a confirmed vulnerability

- Determining the extent of access obtained
- Identifying sensitive systems that could be affected
- Documenting findings for remediation

Phase 7

Reporting

Prepare a report containing

- Executive Summary
- Technical Findings
- Risk Rating
- Screenshots (sample)
- Recommendations
- Conclusion

Part E – Penetration Testing Questionnaire

Imagine you are the penetration tester meeting the client for the first time.

Prepare a questionnaire before starting the assessment.

Organization Details

Infrastructure

Network

Web Applications

Security

Compliance

Rules of Engagement

Deliverables

****Note:** Prepare a Document based on the above-prescribed format (10 – 20 pages).
